



ESCOLA
SUPERIOR
DE REDES

Introdução ao PPSI e à Gestão de Segurança da Informação

Módulo 1

Introdução	3
Objetivos de Aprendizagem	4
Conteúdo	5
Referências	16



Introdução

Vivemos um cenário em que as ameaças digitais ganham contornos cada vez mais complexos e as exigências regulatórias, como a LGPD, impõem um ritmo de adaptação constante. Para os órgãos públicos, o desafio vai além de apenas cumprir regras; trata-se de construir uma estrutura de segurança da informação que seja robusta, resiliente e, acima de tudo, integrada ao dia a dia da instituição. É nesse contexto que o Programa de Privacidade e Segurança da Informação (PPSI) se apresenta não apenas como uma diretriz normativa, mas como o alicerce estratégico para a sobrevivência e a confiabilidade do serviço público.

Este curso, "Elaborando Políticas de Segurança para o PPSI", foi desenhado para ser o seu guia prático nessa jornada de transformação. Ao longo de dez módulos, vamos percorrer todo o ciclo de vida da segurança da informação, desde a governança inicial até a implementação técnica de controles, gestão de riscos, resposta a incidentes e conformidade legal. Nosso objetivo não é oferecer um conteúdo teórico distante da realidade, mas sim capacitar você e sua equipe a escrever, implementar e auditar políticas que realmente funcionem — saindo da burocracia para entregar uma segurança que sustenta a operação, mesmo diante de crises.

Ao final deste curso, o nosso objetivo é que você esteja preparado para alinhar as práticas da sua organização à Portaria SGD/MGI n.º 9.511/2025, reduzindo vulnerabilidades e elevando a maturidade cibernética da instituição. Mais do que atender auditorias, a nossa proposta é ajudar você a disseminar uma cultura de segurança que faça sentido para todos os servidores, transformando diretrizes complexas em ferramentas vivas, práticas e totalmente conectadas às prioridades estratégicas do seu órgão.



Objetivos de Aprendizagem

Ao longo do módulo, você aprofundará seus conhecimentos sobre os conteúdos específicos abordados e, ao final, deverá alcançar os seguintes objetivos de aprendizagem:

1

Alinhamento Normativo: Capacitar o aluno a alinhar as práticas da sua organização às diretrizes da **Portaria SGD/MGI nº 9.511/2025**, que institui o PPSI 2.0.

2

Desenvolvimento de Políticas: Habilitar o participante e sua equipe a **escrever, implementar e auditar políticas de segurança** que sejam funcionais e sustentem a operação institucional, mesmo em situações de crise.

3

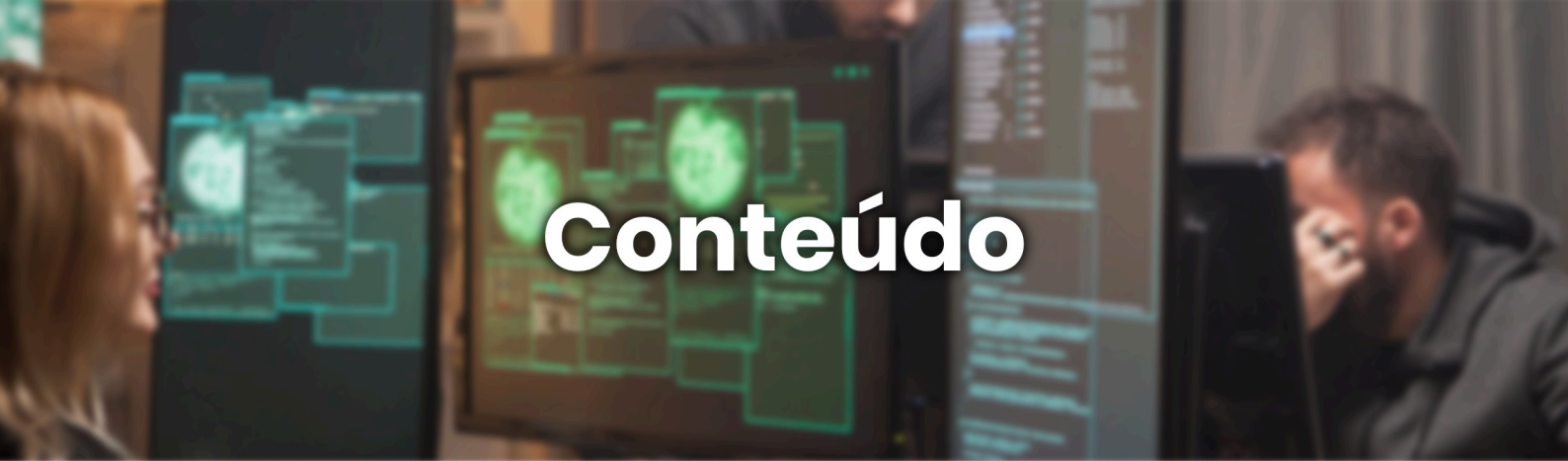
Gestão de Maturidade e Riscos: Preparar o aluno para **reduzir vulnerabilidades e elevar a maturidade e resiliência cibernética** da instituição, utilizando metodologias como o CIS RAM para diagnósticos técnicos.

4

Aplicação de Frameworks Internacionais: Prover uma compreensão sólida de como integrar padrões globais (como **ISO 27001, NIST CSF 2.0 e CIS Controls**) à realidade da administração pública brasileira.

5

Cultura e Engajamento: Disseminar uma **cultura de segurança da informação** que faça sentido para todos os servidores, transformando diretrizes complexas em ferramentas práticas conectadas às prioridades estratégicas do órgão.



Conteúdo

Introdução ao PPSI e à Gestão de Segurança da Informação

O que é o PPSI e sua importância para a administração pública

No dia a dia do setor público, a segurança da informação é frequentemente vista como um conjunto de travas técnicas ou obrigações burocráticas. O Programa de Privacidade e Segurança da Informação (PPSI), instituído pela Portaria SGD/MGI nº 9.511/2025 (em vigor a partir de 01/01/2026), nasce para mudar essa lógica.

Pense no PPSI não como uma "lista de regras", mas como o alicerce estratégico do seu órgão. Ele é o mapa que organiza como protegemos os dados — sejam do cidadão ou da própria instituição — durante todo o seu ciclo de vida. O grande diferencial do programa é harmonizar a necessidade de seguir leis complexas (como a LGPD) com boas práticas internacionais (como ISO 27001, NIST e CISControls), transformando o dever constitucional de proteger dados em um sistema de trabalho eficiente.

Por que o PPSI é indispensável hoje?

O PPSI é indispensável hoje porque profissionaliza a gestão de risco no Estado. Ele unifica governança, controle técnico e cultura organizacional, permitindo que a Administração Pública evolua de uma postura reativa para uma atuação estratégica. O resultado prático dessa implementação é a garantia de que as informações críticas permaneçam confidenciais, íntegras e disponíveis, consolidando a confiança do cidadão nos serviços estatais.

Estrutura Organizacional e Objetivos do PPSI

Conforme o disposto na Portaria SGD/MGI nº 9.511/2025, o PPSI 2.0 tem como objetivo elevar a maturidade e a resiliência dos órgãos e entidades em termos de privacidade e

segurança da informação no âmbito do SISP.

Para não criar burocracia excessiva, o PPSI organiza cinco papéis estratégicos que devem atuar em sintonia, evitando que a segurança fique isolada em "silos":

Alta Administração:

Provê direcionamento estratégico, decisões críticas e liberação de recursos necessários para o programa.

Gestor de TI:

Desenha e executa controles de segurança específicos no ambiente tecnológico e na cadeia de suprimentos.

Gestor de Segurança da Informação:

Realiza diagnósticos técnicos profundos e modela as salvaguardas de proteção.

Encarregado (DPO):

Guardião das garantias de privacidade, assegurando o cumprimento das regras de proteção de dados pessoais.

Responsável pela Integridade:

Atua na articulação integrada, evitando que os processos institucionais funcionem de forma isolada.

Regulamentado pelo art. 4º da Portaria, o programa opera através de cinco eixos temáticos articulados: Governança, Maturidade, Metodologia, Pessoas e Tecnologia. Estes pilares complementares asseguram a proteção dos ativos e a conformidade regulatória no ecossistema do Sistema de Administração dos Recursos de Tecnologia da Informação (SISP).

1

Governança: Garante a coordenação estratégica, o alinhamento a políticas públicas e a otimização de recursos institucionais.

2

Maturidade: Foca na avaliação contínua e no aprimoramento dos controles de privacidade e segurança do órgão.

3

Metodologia: Padroniza a gestão de riscos e processos de adequação, utilizando referências como ISO 27005 ou CIS RAM.

4

Pessoas: Promove a cultura de segurança através de planos de conscientização, treinamentos e engajamento dos servidores.

5

Tecnologia: Define a implementação técnica de controles, ferramentas de proteção e segurança na cadeia de suprimentos de TI.

Para dar suporte a essa estrutura, o programa conta com dois centros nacionais de excelência: o **CISC gov.br**, que atua na linha de frente da prevenção e resposta a incidentes, e o **CEPS gov.br**, focado em promover a cultura de privacidade e segurança por meio de capacitação e boas práticas, além claro da **REGIC** (Rede de Federal de Gestão de Incidentes Cibernéticos). Qualquer plano de conscientização institucional deve buscar articulação com essas iniciativas nacionais, ganhando escala e legitimidade.

O Ciclo de Execução: PPSI na prática

O PPSI não é estático; ele funciona em um ciclo contínuo composto por diagnóstico, análise de lacunas, planejamento e implementação. Nesse fluxo, o órgão avalia sua situação atual, identifica o que falta, planeja ações e implementa melhorias. Esse processo gera resultados que precisam ser documentados e reportados à Secretaria de Governo Digital (SGD). Em suma, o PPSI converte normas complexas em um método de trabalho vivo, onde o objetivo final não é apenas o "selo de conformidade", mas a resiliência e a maturidade cibernética que o órgão precisa para enfrentar ameaças reais.

Conceitos Fundamentais de Segurança da Informação: A Tríade CIDA

A base para a proteção de sistemas e dados contra ameaças digitais fundamenta-se em três pilares essenciais de segurança da informação, amplamente conhecidos pela sigla CIDA: Confidencialidade, Integridade, Disponibilidade e Autenticidade.

A **confidencialidade** garante que as informações sejam acessadas apenas por pessoas autorizadas, protegendo dados sensíveis contra acessos indevidos, espionagem ou vazamentos — na prática, isso se traduz em criptografia, controle de acesso por senha e autenticação multifator.

A **integridade** assegura que a informação não seja alterada de forma indevida, seja por erro ou por ação maliciosa, mantendo a exatidão e a confiabilidade dos dados ao longo do tempo por meio de assinaturas digitais, somas de verificação e controle de versões.

A **disponibilidade**, por sua vez, garante que a informação e os sistemas estejam acessíveis sempre que necessário, evitando interrupções nos serviços por meio de backups, redundância de servidores e planos de continuidade de negócios.

E a **autenticidade** confirma a identidade de usuários ou sistemas que acessam ou transmitem informações, prevenindo fraudes e garantindo que a comunicação seja confiável. Métodos comuns incluem autenticação multifator, certificados digitais e protocolos de verificação de identidade.

Esses quatro pilares operam de maneira interdependente, de modo que a fragilidade de um deles compromete a eficácia de todo o ecossistema de proteção. Portanto, o desenvolvimento de uma política de segurança eficiente exige um equilíbrio contínuo entre esses conceitos, ajustando-se às prioridades estratégicas e aos riscos específicos de cada organização.

Visão Geral das Normas e Frameworks de Referência (ISO 27001, CIS, NIST, LGPD, GDPR)

Com o objetivo de proporcionar uma compreensão mais nítida sobre o suporte dessas diretrizes, apresentamos a seguir uma síntese dos conceitos fundamentais que estruturam sua base técnica.

Norma ISO/IEC 27001

Como padrão internacional consagrado, a ISO/IEC 27001 estabelece os requisitos indispensáveis para a concepção, implementação, manutenção e aprimoramento contínuo de um Sistema de Gestão de Segurança da Informação (SGSI). A finalidade central dessa norma é salvaguardar os ativos de informação por meio de uma estrutura consolidada de políticas, processos e controles, assegurando de forma constante a confidencialidade, a integridade e a disponibilidade dos dados organizacionais.

Fundamentada no ciclo dinâmico do PDCA (*Plan-Do-Check-Act*), a norma consolida um modelo de governança que unifica e integra processos, pessoas e recursos tecnológicos — pilares que também sustentam o Programa de Privacidade e Segurança da Informação sob a Portaria SGD/MGI n.º 9.511/2025. No contexto da administração pública, ela atua como um guia metodológico essencial para a identificação e tratamento de riscos, estruturação de salvaguardas técnicas, definição de responsabilidades e acompanhamento da melhoria contínua, organizando-se em diretrizes como liderança, planejamento, apoio, operação, avaliação de desempenho e ações corretivas.

CIS – Center for Internet Security

O CIS Controls v8.1 consiste em uma estrutura prioritária de 18 controles de segurança pragmáticos, formulados a partir do mapeamento de ameaças reais e incidentes históricos. É amplamente adotado em escala global como um roteiro prático e focado para a mitigação mensurável de riscos de segurança digital.

Em complemento, o CIS RAM (*Center for Internet Security Risk Assessment Method*), desenvolvido em parceria com a HALOCK Security Labs, constitui uma metodologia de avaliação de riscos ágil e estruturada. Seu propósito é viabilizar que as instituições apliquem os Controles CIS de acordo com suas realidades de negócio e necessidades específicas de segurança.

Graças a essa flexibilidade de aplicação, a modelagem se ajusta a organizações de variados portes e setores, propiciando que as medidas defensivas correspondam precisamente aos limites de risco tolerados por cada entidade.

O método CIS RAM orienta as organizações na busca por respostas a questões como:

Quais são as ameaças e os riscos reais que impactam nossa organização?

O que determina uma postura de "devido cuidado" ou de "razoabilidade" em nossa defesa?

Qual é o nível ideal e suficiente de investimento em segurança?

Princípios do CIS RAM

1. A análise de riscos deve englobar de forma ativa os interesses de todas as partes potencialmente impactadas pelas ameaças identificadas.
2. Os riscos cibernéticos precisam ser reduzidos a patamares aceitáveis que mitiguem a necessidade de soluções emergenciais ou onerosas para qualquer um dos envolvidos.
3. O custo e o esforço de implementação das salvaguardas recomendadas não devem superar a gravidade dos riscos dos quais se busca proteção.

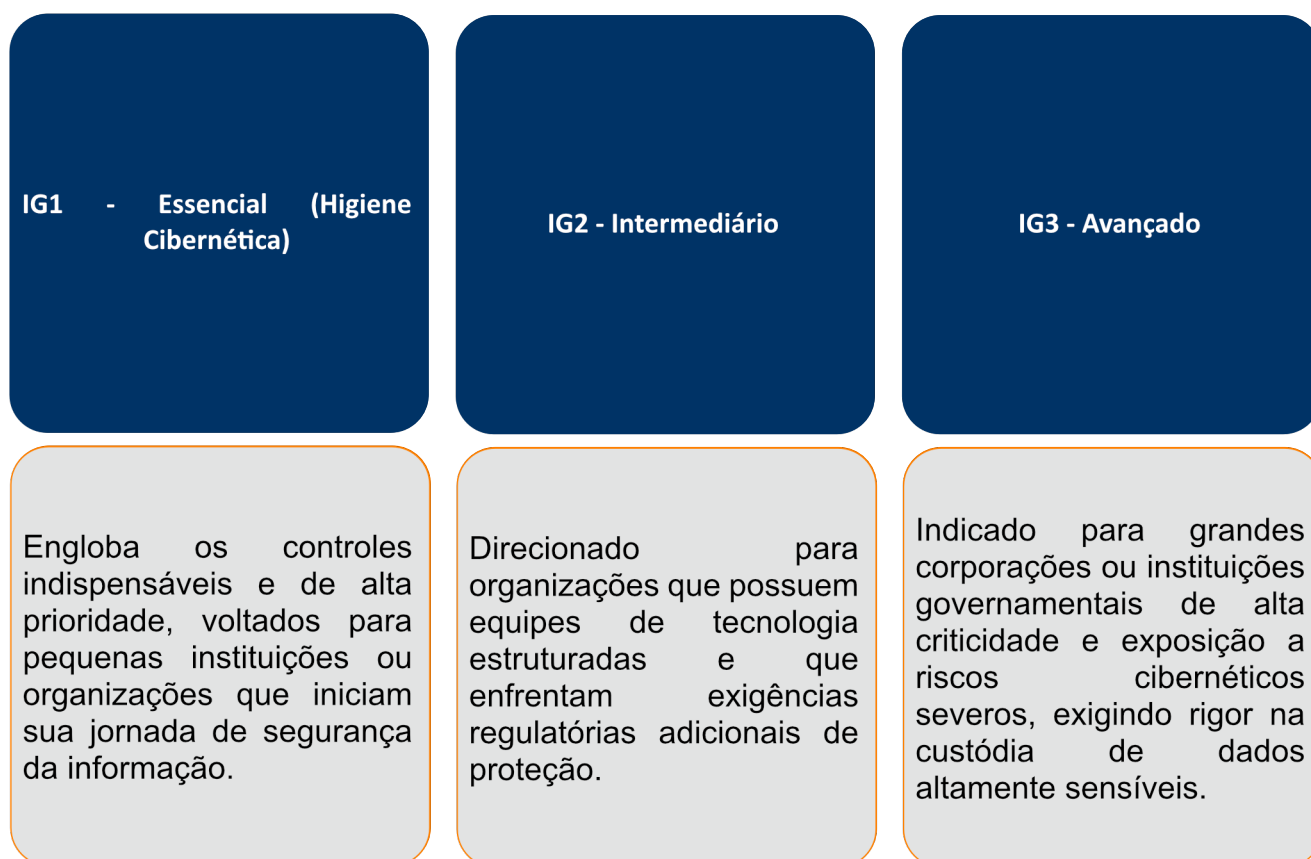
Práticas Recomendadas - CIS RAM

1. As avaliações estimam a probabilidade de que ameaças explorem vulnerabilidades e gerem impactos adversos de variadas proporções.
2. Os níveis toleráveis de risco são definidos de forma clara e simples, aplicando-se uniformemente em cada etapa do processo de análise de riscos.
3. Os índices de probabilidade e impacto possuem definições qualitativas consistentes, expressando diretamente as preocupações do negócio, das autoridades reguladoras e dos analistas.
4. As métricas de análise também derivam de cálculos quantitativos, viabilizando o monitoramento comparativo entre riscos tratados, controles implantados e critérios aceitos de tolerância.
5. Os parâmetros de impacto garantem que a gravidade das consequências para diferentes partes interessadas seja mensurada com o mesmo peso e critério.
6. As definições de impacto devem estipular uma linha divisória clara entre o que constitui um prejuízo aceitável a todos e o que viola a conformidade ou a operação.
7. Os critérios de impacto devem alinhar-se à missão organizacional, explicitando as justificativas da exposição ao risco, os objetivos estratégicos internos e os compromissos de proteção a terceiros.
8. O processo de diagnóstico apoia-se em padrões rigorosos de diligência técnica para validar a eficácia dos mecanismos atuais e recomendar novas barreiras.
9. A modelagem e avaliação de cenários dependem da contribuição direta de especialistas que se baseiam em evidências robustas para avaliar vulnerabilidades e salvaguardas.
10. Uma única rodada de diagnóstico não é capaz de prever todas as ameaças possíveis; desse modo, as avaliações devem ser realizadas de forma cíclica e periódica para mitigar novos cenários de risco ao longo do tempo.

A metodologia do CIS RAM está consolidada sobre o conceito central de razoabilidade da segurança. Assim, além de estruturar as vulnerabilidades técnicas, o escopo de análise foca em ponderar a proteção dos ativos frente ao custo de implementação e viabilidade das contramedidas. Esse processo torna-se um artefato valioso para prestar contas perante as esferas reguladoras e parceiros estratégicos, evidenciando formalmente que os investimentos e políticas foram pautados em "razoabilidade", "devido cuidado" e "adequação institucional".

A adoção do CIS RAM também habilita as organizações a mapearem seu grau de maturidade cibernética de forma estruturada. Essa apuração atribui uma pontuação de "1" a "5" a cada controle de segurança, indicando com clareza a confiabilidade e a solidez operacional da medida avaliada.

Na arquitetura global do CIS Controls v8.1, os 18 domínios de controle de segurança são estruturados em três grandes faixas evolutivas, conhecidas como Grupos de Implementação (*Implementation Groups - IGs*), definidos por:



Eixo de Maturidade	Visão Estratégica	Controles Estruturados
 EIXO I: HIGIENE	Proteção Essencial Foco em visibilidade e controle inicial.	[01] Inv. Hardware; [02] Inv. Software; [03] Prot. Dados; [04] Config. Segura; [05] Gerenciamento de contas; [06] Controle de acesso; [07] Gerenciamento Contínuo de Vulnerabilidades; [08] Auditoria e Gerenciamento de Logs; [09] Email e Proteção Web; [10] Defesa anti Malware; [11] Recuperação de dados; [12] Gerenciamento de Infraestrutura de Rede; [14] Treinamento de Conscientização e Habilidades de Segurança; [15] Gestão de Provedor de Serviço; [17] Gerenciamento de Resp. Incidentes;
 EIXO II: DEFESA	Proteção Ativa Foco em resiliência e defesa técnica.	Todos do Eixo HIGIENE; [16] Segurança de Aplicações; [18] Penetration Test.
 EIXO III: GOVERNANÇA	Maturidade e Processo Foco em análise e melhoria contínua.	Todos os controles e salvaguardas

Dashboard de Controles CIS v8.1: O Caminho da Maturidade

Passo a Passo das Avaliações com o CIS RAM

Para converter análises abstratas em diagnósticos de segurança acionáveis, o CIS RAM Core estrutura seu processo de avaliação de risco em cinco etapas fundamentais:

1

Estabelecimento de Critérios: Determine de forma inequívoca as regras de medição e os limites de aceitação de risco para nortear o processo.

2

Modelagem de Cenários: Avalie o desempenho das defesas atuais recomendadas pelo CIS diante de ameaças reais e mapeadas.

3

Análise de Riscos: Faça a estimativa de impacto e probabilidade para calcular o nível de risco, definindo de maneira clara as tolerâncias institucionais.

4

Proposta de Salvaguardas: Indique quais controles do CIS são ideais para mitigar de forma direta os riscos classificados como intoleráveis.

5

Validação das Contramedidas: Certifique-se de que os controles propostos de fato reduzem a exposição, sem impor barreiras operacionais ou despesas desproporcionais.

O Guia CIS Privacy Companion: Alinhando Segurança Técnica e Privacidade

Projetado como uma extensão estratégica dos Controles Críticos de Segurança (CIS Controls v8.1), o *CIS Privacy Companion Guide* atua como um elo entre a proteção técnica de sistemas e as normas legais de privacidade, incluindo a LGPD. Em vez de tratar a segurança e a privacidade como áreas separadas, este guia traduz controles técnicos abstratos em ações

🔑 Conceito Chave

Privacidade define 'o que' deve ser protegido; Segurança da informação define 'como' proteger.

Na prática, o guia mapeia os 18 controles do CIS v8.1 frente aos princípios fundamentais de privacidade. Isso significa que, ao implementar uma medida de segurança, o gestor é orientado a garantir que ela também atenda a diretrizes como:

- **Minimização de dados e Limitação de propósito:** Assegurando que apenas os dados estritamente necessários sejam tratados e para fins claramente definidos.
- **Transparência e Direitos do Titular:** Garantindo que o cidadão seja informado e tenha autonomia sobre suas informações, podendo acessar, retificar ou contestar o tratamento.
- **Consentimento e Responsabilização:** Estabelecendo mecanismos auditáveis de autorização e de prestação de contas.

A adoção desta abordagem transforma a conformidade legal em uma prática contínua e operacional. Ao combinar os controles técnicos do CIS com a estrutura do PPSI, a organização não apenas reduz riscos cibernéticos de forma mensurável, mas fortalece a confiança institucional, demonstrando que a proteção de dados pessoais é uma responsabilidade estruturada, técnica e, acima de tudo, focada na segurança das pessoas.

⊕ Saiba Mais

O CIS Controls v8.1 ajuda você a se manter atualizado sobre seu local de trabalho em evolução, a tecnologia necessária para apoiá-lo e as ameaças enfrentadas por esses sistemas. Ele coloca ênfase específica na mudança para um ambiente híbrido ou totalmente em nuvem e no gerenciamento da segurança em toda a sua cadeia de suprimentos.

[Acesse aqui](#)

Cybersecurity Framework 2.0: Seu Guia Estratégico

Mais do que um simples conjunto de regras técnicas, o NIST CSF 2.0 funciona como um guia estratégico. Ele orienta as organizações na construção de uma postura resiliente, integrando a segurança cibernética diretamente aos objetivos de negócio e à gestão de riscos operacionais.

A jornada para a maturidade cibernética através do NIST é composta por seis funções fundamentais, organizadas de forma lógica e sequencial:

Governar (Govern):

O alicerce. Define a estratégia, as responsabilidades e a supervisão da gestão de riscos.

Identificar (Identify):

O mapeamento. Compreende os ativos, o ambiente e as vulnerabilidades para priorizar esforços.

Proteger (Protect):

A prevenção. Implementa salvaguardas para conter ameaças e garantir a continuidade dos serviços.

Detectar (Detect):

A vigilância. Monitora o ambiente para identificar rapidamente a ocorrência de incidentes.

Responder (Respond):

A ação. Executa medidas imediatas para conter e mitigar o impacto de um ataque detectado.

Recuperar (Recover):

A resiliência. Restaura capacidades e serviços, aprendendo com o evento para fortalecer a defesa.

Para personalizar essa estrutura, o framework utiliza os **Perfis Organizacionais**, que alinham as ações de segurança às necessidades específicas e recursos do órgão. Complementarmente, os **Níveis (Tiers)** fornecem uma escala de maturidade para avaliar quão rigorosos e integrados são os processos de gestão de risco, permitindo uma evolução contínua e mensurável.

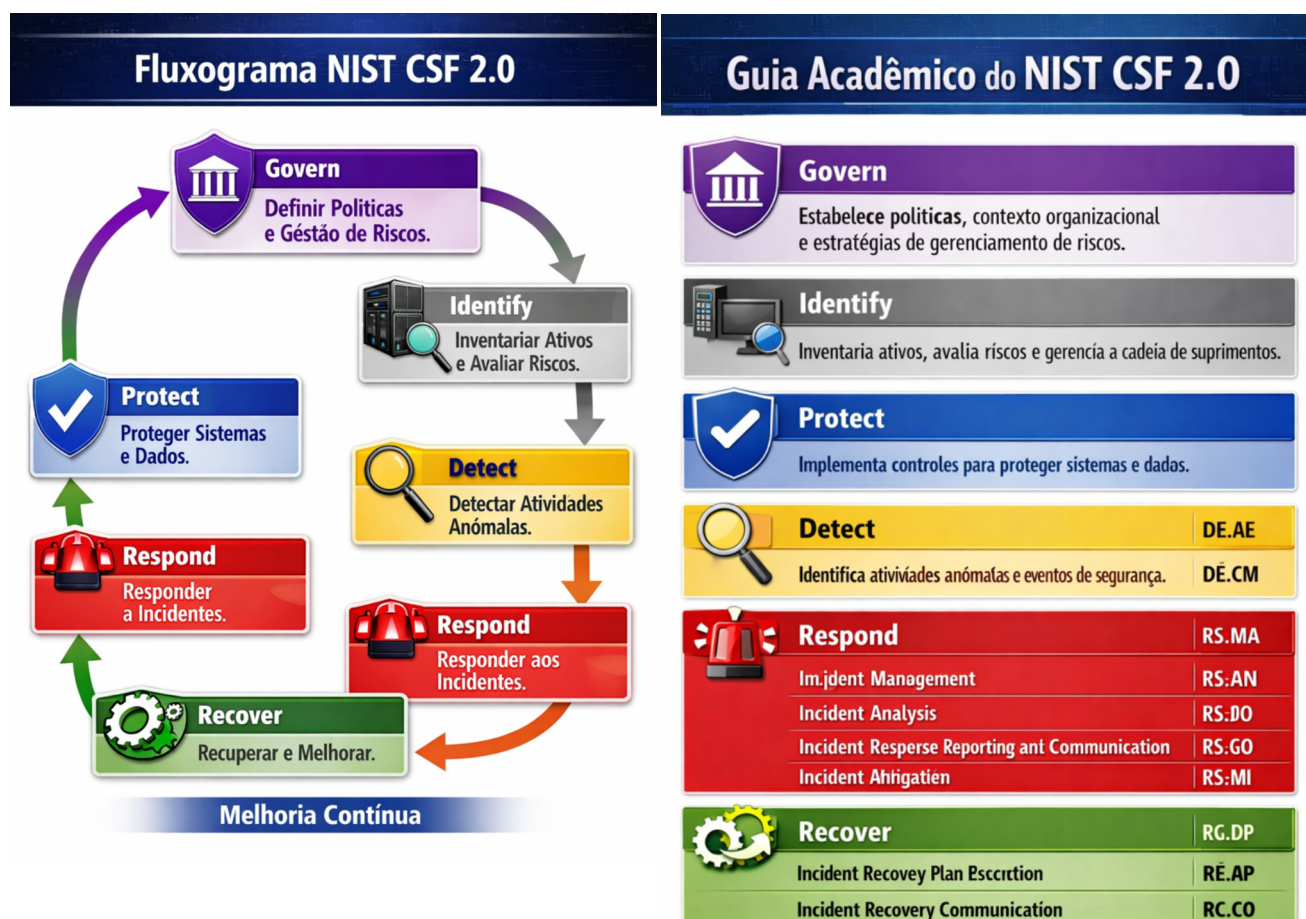


Figura 1 – NIST Cybersecurity Framework 2.0 (Fonte: <https://www.nist.gov/system/files/documents/2023/04/24/NIST%20Cybersecurity%20Framework%202.0%20Core%20Discussion%20Draft%204-2023%20final.pdf>).

O CSF 2.0 é projetado para ser flexível e adaptável, permitindo que organizações:

Avaliem e melhorem sua postura de segurança cibernética.

Promovam a comunicação interna e externa sobre riscos de segurança cibernética.

Alinhe as atividades de segurança cibernética com os objetivos de negócios e a gestão de riscos empresariais.

Integrem com outras estruturas e padrões, como ISO/IEC 27001, NIST SP 800-53, e o Programa de Privacidade e Segurança da Informação (PPSI).

Ao converter a segurança cibernética de uma barreira técnica em uma **estratégia de gestão e resiliência organizacional**, o **NIST Cybersecurity Framework** auxilia organizações públicas e privadas na estruturação de suas defesas. Sua adoção fundamenta-se em **princípios consolidados, na priorização de riscos reais e no estabelecimento de processos auditáveis**.

Diante das ameaças contemporâneas, a questão central **não é mais "se" ocorrerá um incidente, mas sim "quando" ele acontecerá**. A capacidade de resposta imediata,

preparação e resiliência distingue as instituições maduras daquelas expostas, consolidando o **NIST CSF** como o roteiro ideal para essa jornada.

LGPD

A Lei Geral de Proteção de Dados Pessoais (LGPD – Lei nº 13.709/2018) foi promulgada para proteger os direitos fundamentais de liberdade, privacidade e livre formação da personalidade de cada indivíduo, regulando o tratamento de dados pessoais realizado por pessoa física ou jurídica, de direito público ou privado, em meio físico ou digital. A lei estabelece fundamentos como o respeito à privacidade e a autodeterminação informativa (art. 2º), princípios como finalidade, adequação, necessidade e transparência (art. 6º), e hipóteses legais que autorizam o tratamento de dados pessoais (art. 7º). Ela também disciplina o tratamento de dados sensíveis, de crianças e adolescentes, os direitos dos titulares, a responsabilidade dos agentes de tratamento e a atuação da Autoridade Nacional de Proteção de Dados (ANPD), órgão federal responsável por fiscalizar, orientar e regulamentar sua aplicação. No contexto do PPSI, a LGPD funciona como um dos pilares normativos centrais, articulando-se diretamente com controles específicos de privacidade, como os tratados nos guias complementares de elaboração do Registro das Operações de Tratamento (ROPA) e de Avisos de Privacidade.

A Lei Geral de Proteção de Dados (LGPD - Lei 13.709/2018) representa um marco histórico na defesa da privacidade e da autonomia dos cidadãos na era digital. Ao estabelecer regras claras para o tratamento de dados pessoais, a lei não apenas protege os direitos individuais, mas também promove um ambiente de transparência e confiança entre organizações, governo e sociedade.

Chegamos ao final deste primeiro módulo, esperamos que vocês tenham uma compreensão sólida da importância estratégica do Programa de Privacidade e Segurança da Informação (PPSI 2.0) e do papel fundamental que *frameworks* como o *NIST Cybersecurity Framework 2.0* desempenham na construção de uma postura de segurança cibernética robusta e adaptável. A segurança da informação, como vimos, transcende a mera conformidade técnica; ela é um processo contínuo de gestão de riscos, que exige governança clara, metodologias eficazes, tecnologias adequadas e, acima de tudo, o engajamento e a conscientização de todas as pessoas envolvidas.

Referências

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Portaria SGD/MGI nº 9.511, de 2025. Institui a Política Nacional de Segurança da Informação no âmbito da administração pública federal. Disponível em: <https://www.in.gov.br/>. Acesso em: 15 jul. 2026.

BRASIL. Presidência da República. Decreto nº 7.579, de 11 de outubro de 2011. Dispõe sobre a Política de Segurança da Informação nos órgãos e entidades da administração pública federal. Diário Oficial da União: seção 1, Brasília, DF, 13 out. 2011. Disponível em: https://www.planalto.gov.br/ccivil_03/ato2011-2014/2011/decreto/d7579.htm. Acesso em: 23 maio 2025.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Guia do Framework de Privacidade e Segurança da Informação. Versão 1.1.4. Brasília, DF, dez. 2024. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/guia_framework_psi.pdf. Acesso em: 23 maio 2025.

BRASIL. Presidência da República. Decreto nº 7.579, de 11 de outubro de 2011. Dispõe sobre o Sistema de Administração dos Recursos de Tecnologia da Informação (SISP). Diário Oficial da União: seção 1, Brasília, DF, 13 out. 2011.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União: seção 1, Brasília, DF, 15 ago. 2018.

CENTER FOR INTERNET SECURITY. CIS Critical Security Controls v8. East Greenbush, NY: CIS, 2021.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva, 2022.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. The NIST Cybersecurity Framework (CSF) 2.0. Gaithersburg, MD: NIST, 2024.